MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 064 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

ARGUMENT · PERSONNEL SECURITY

3.9.2 Fails on the Transfer, Not the Termination

NIST 800-171 control 3.9.2 is worth 5 SPRS points. Firings are handled. The engineer who moved to a commercial program and kept enclave access is not.

BY MAXINE
READING TIME · 5 MIN
NIST-800-171 · PERSONNEL-SECURITY · ACCESS-CONTROL · CMMC-LEVEL-2 · SPRS

he objection comes first, and it deserves a fair hearing: personnel security is the most boring family in NIST SP 800-171, and requirement 3.9.2 is the most boring control in it. Someone leaves, HR tells IT, IT disables the account. Every small defense contractor already does this, because nobody wants a fired employee reading the company email from home. If any control in the 110 can be checked off on instinct, surely it is this one.

The instinct is right about terminations. It is wrong about the requirement, which says more than most programs read into it. The text is "Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers." The DoD Assessment Methodology weighs it at 5 points, the top of the scale. And NIST SP 800-171A splits it into three objectives that an assessor scores separately: a policy or process for ending access and credentials coincident with personnel actions, evidence that access and credentials actually ended consistent with those actions, and evidence that the system is protected during and after a transfer. Miss any one and the full 5 points come off the score.

That third objective is the one small programs are least equipped to meet, and the reason is structural rather than careless.

A transfer files no ticket

A termination is an event the whole company notices. Payroll stops, a badge goes in a drawer, and the HR system emits the record that IT has learned to act on. A transfer generates none of that. The engineer who spent two years on the Army sustainment contract and moves in October to the company's commercial product line still draws the same paycheck, sits at the same desk, and logs in with the same identity. Nothing in the workflow tells anyone that the enclave group, the VPN profile, the shared drive mapping and the seat on the CUI distribution list are now access the engineer no longer needs.

So the access stays, sometimes for years. It is not malicious and usually not even noticed. It surfaces when an assessor does the thing the 800-171A methods describe. The examine list for 3.9.2 names records of personnel transfer and termination actions, the list of system accounts, and records of terminated or revoked authenticators and credentials. Put the first two side by side and the transferred engineer appears as a mismatch: a name whose current role has nothing to do with CUI, holding an account that does.

> *The termination is the personnel action everyone sees. The transfer is the one only the account list remembers.*

The same gap opens on smaller moves. A systems administrator promoted into a program management role keeps domain admin because revoking it felt like a demotion. A quality inspector who covered the CUI receiving desk for a month during a vacancy keeps the folder permissions after the vacancy is filled. None of these people left the company. Each is a personnel action in the plain sense of the requirement, and each leaves the system less protected after it than before.

What the termination checklist still misses

Granting the objection its due, terminations deserve a second look too, because the directory account is the credential that gets disabled and it is rarely the only one. Objective [b] says access and credentials, and the examine list says authenticators. A departing employee may hold a hardware token, a smart card, a local administrator account on a machine tool controller that never joined the domain, a login to a prime's supplier portal, or the certificate a company uses to report incidents under DFARS 252.204-7012, which requires a DoD-approved medium assurance certificate to file at DIBNet. Disabling the directory account touches none of those.

Shared credentials are the harder case. If three engineers know the password to the test bench's local account and one leaves, the credential the departing person holds has not been revoked until the password changes. Programs that cannot say who knows which shared secret cannot show that a termination ended that person's access, and the objective asks them to show exactly that.

FIELD COPY
ISSUE Nº 064
NIST 800 171

The evidence an assessor can actually score

The requirement names no hour count. Objective [a] says access ends coincident with the personnel action, and the program defines what that means in its own policy. What the assessor tests is whether the program does what its policy says, using the mechanisms 800-171A lists: the notification that tells IT a personnel action happened, and the mechanism that disables access and revokes authenticators.

For a company of twenty or two hundred, that evidence is not exotic. It is three things kept together. First, a written trigger list that treats a transfer, a role change, and the end of temporary coverage as personnel actions alongside a termination, so that HR files the same notice for each. Second, a record per action showing the date of the action, the accounts and credentials touched, and the date each was disabled or reduced, including the ones outside the directory. Third, a periodic reconciliation of the HR roster against every account with access to CUI, signed and dated, with each mismatch either explained or closed.

The third item is the one that catches the transfers the first two missed, and it is the one most programs skip because it produces findings. That is the point of running it. A reconciliation that finds a stale account on a Tuesday in November is a corrected process with a record attached. The same account found by an assessor is a 5-point deduction on 3.9.2 and an argument about 3.1.1 and 3.1.5 that the program will lose.

Run the reconciliation before the next personnel change rather than after it, and keep the dated export alongside the system security plan that describes the process. If a reconciliation has never been run, the first one is the most useful hour a small program can spend on its Level 2 readiness this month, and a readiness check will show what else is sitting in the same blind spot. ◆

5

SPRS POINTS 3.9.2 CARRIES IN THE DOD ASSESSMENT METHODOLOGY, LOST IN FULL IF ANY ONE OF ITS THREE OBJECTIVES IS UNMET

3

ASSESSMENT OBJECTIVES IN NIST SP 800-171A FOR 3.9.2, AND THE THIRD IS ABOUT TRANSFERS ALONE

0

HOURS NAMED IN THE REQUIREMENT TEXT. THE OBJECTIVE SAYS ACCESS ENDS COINCIDENT WITH THE PERSONNEL ACTION

◆ THE CONTROLS THAT RIDE ALONG

An account a transferred employee no longer needs also touches 3.1.1, limit system access to authorized users (5 points), and 3.1.5, least privilege (3 points). An assessor who finds one stale account rarely scores only one requirement against it.